

Digital Signature

Conventional signatures and digital signatures

- A conventional signature is included in the document; it is part of the document.
- But when we sign a document digitally, we send the signature as a separate document.

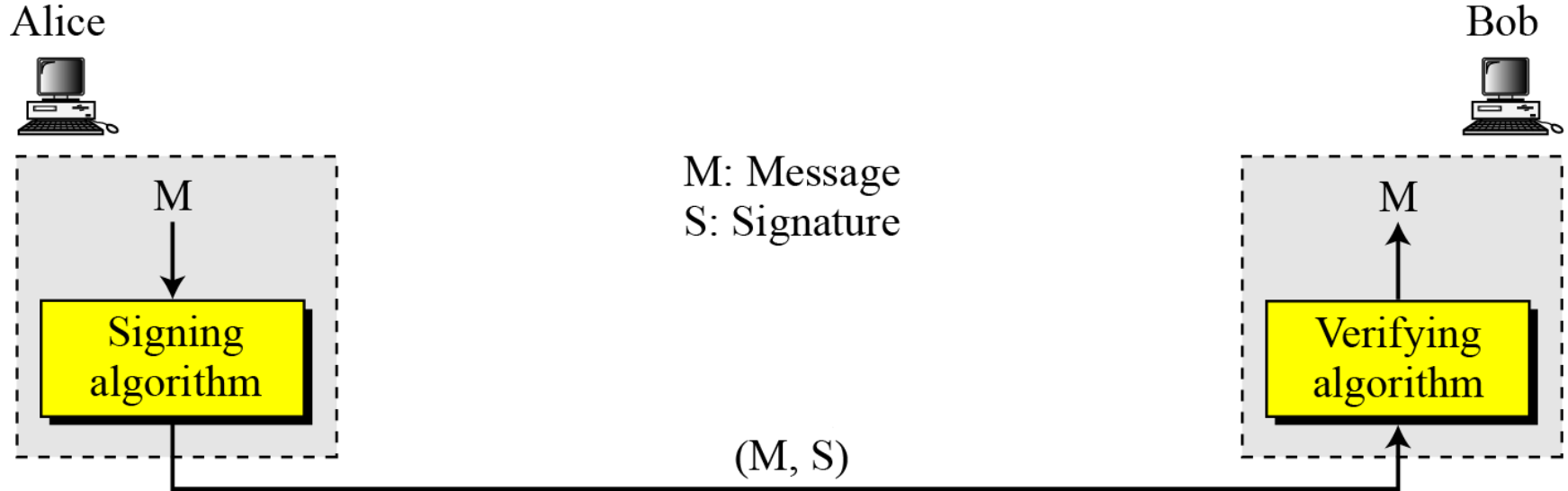
Verification Method

- For a **conventional signature**, when the recipient receives a document, she compares the signature on the document with the signature on file.
- For a **digital signature**, the recipient receives the message and the signature. The recipient needs to apply a verification technique to the combination of the message and the signature to verify the authenticity.

Relationship

- For a **conventional signature**, there is normally a one-to-many relationship between a signature and documents.
- For a **digital signature**, there is a one-to-one relationship between a signature and a message.

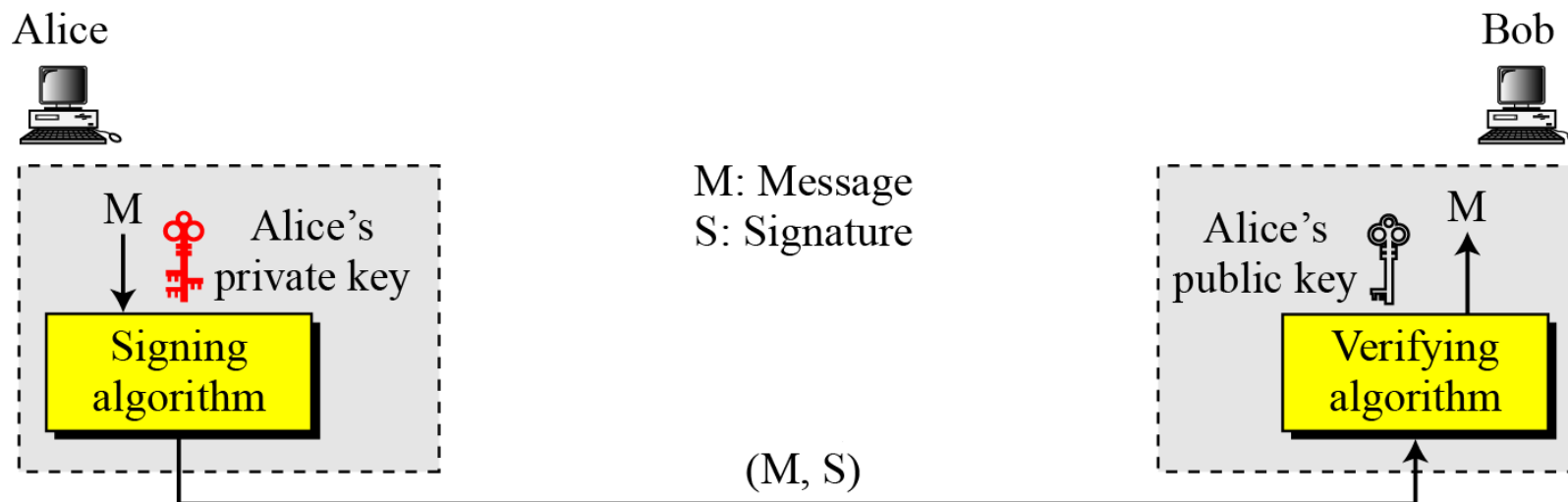
Digital signature process



- The sender uses a signing algorithm to sign the message.
- The message and the signature are sent to the receiver.
- The receiver receives the message and the signature and applies the verifying algorithm to the combination.
- If the result is true, the message is accepted; otherwise, it is rejected.

Need for Keys

- A digital signature needs a public-key system.
- The signer signs with her private key; the verifier verifies with the signer's public key.

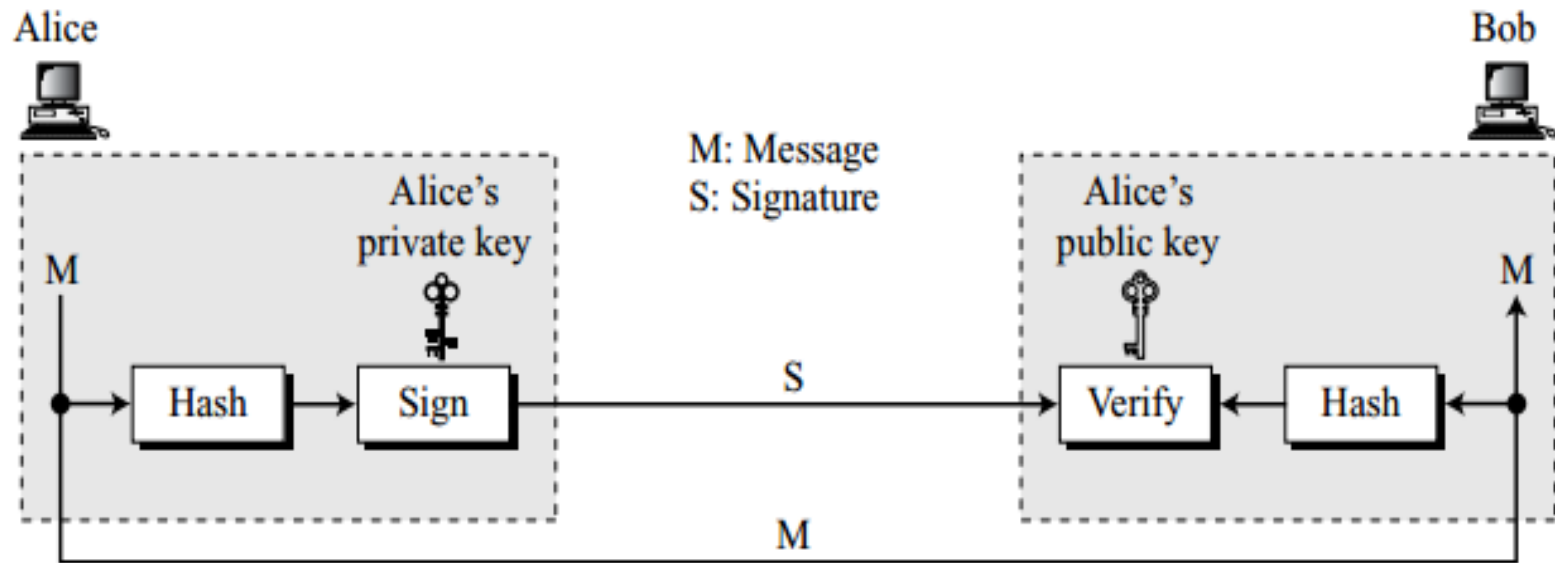


A digital signature uses the private and public keys of the sender.

Signing the Digest

- The asymmetric-key cryptosystems are very inefficient when dealing with long messages.
- In a digital signature system, the messages are normally long, but we have to use asymmetric-key schemes.
 - The solution is to sign a digest of the message, which is much shorter than the message.

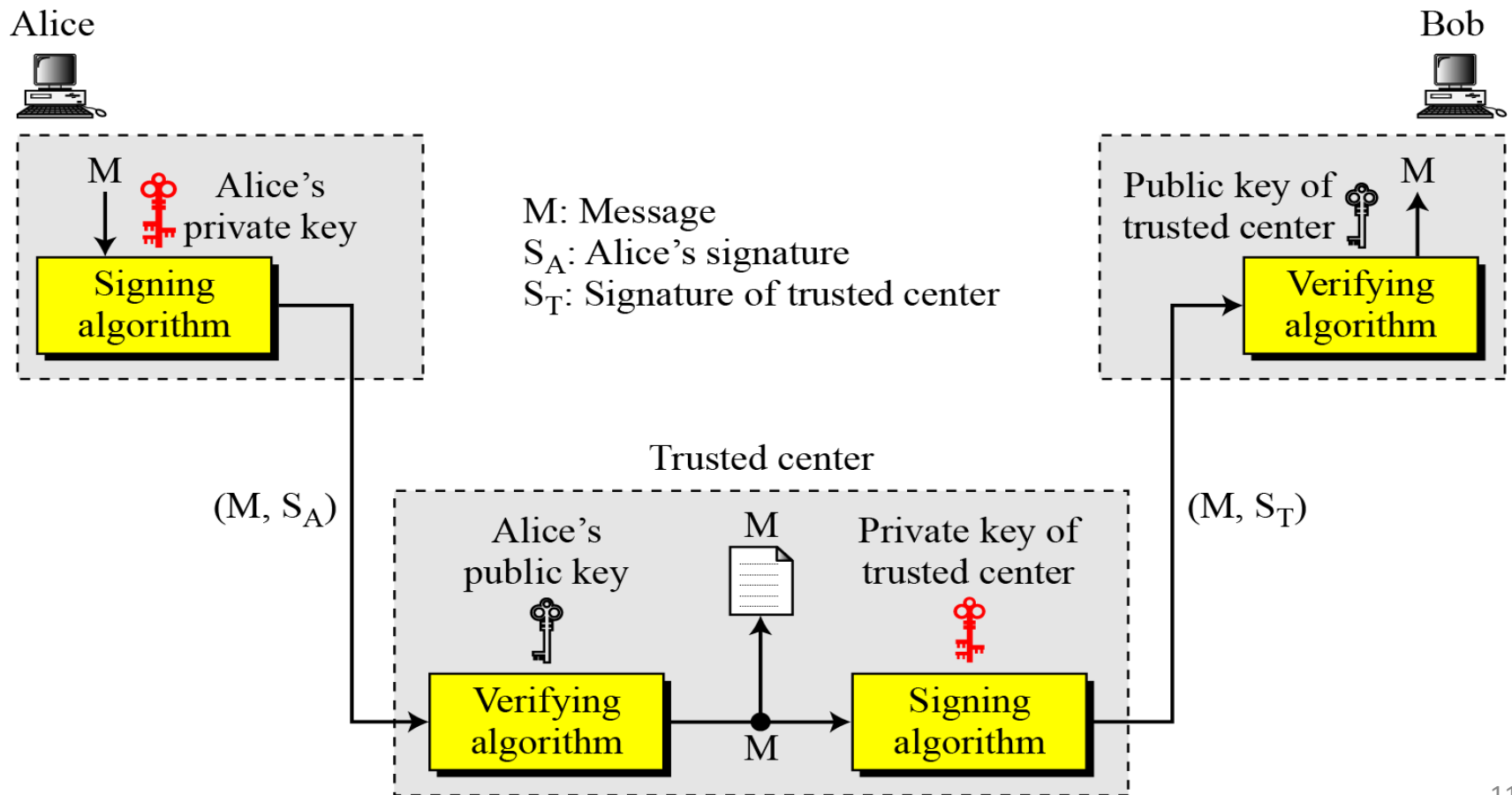
Signing the Digest



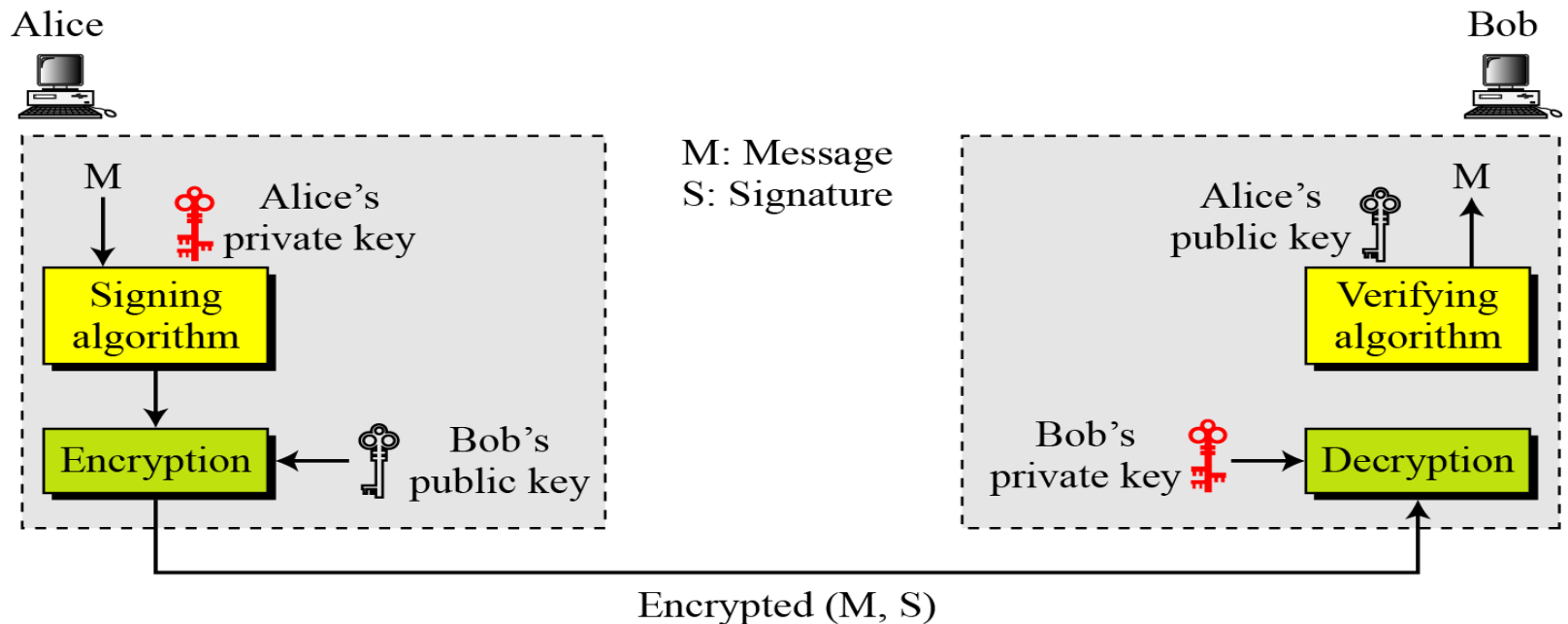
Services provided by digital signature

- A digital signature provides **message authentication, message integrity**.
- Signatures provide non-repudiation with help of a trusted party.
 - ensuring that a party in a dispute cannot repudiate, or refute the validity of a statement

Using a trusted center for nonrepudiation



- A digital signature does not provide **privacy or confidentiality**. If there is a need for privacy, another layer of encryption/decryption must be applied.



Attacks on digital signatures

- **Key-Only Attack**
 - Eve has access only to the public information released by Alice.
 - To forge a message, Eve needs to create Alice's signature to convince Bob that the message is coming from Alice.
- **Known-Message Attack**
 - Eve has access to one or more message-signature pairs.
 - Eve tries to create another message and forge Alice's signature on it.

Attacks on digital signatures

- Chosen-Message Attack
 - similar to the chosen-plaintext attack

Forgery Types

- If the attack is successful, the result is a forgery.
- We can have two types of forgery: existential and selective.
- In an **existential forgery**, Eve may be able to create a valid message-signature pair, but not one that she can really use.
- In **selective forgery**, Eve may be able to forge Alice's signature on a message with the content selectively chosen by Eve.

Digital Signature Properties

- Must depend on the message signed
- Must use information unique to sender
 - to prevent both forgery and denial
- Must be relatively easy to produce, recognize & verify
- Be computationally infeasible to forge
 - with new message for existing digital signature
 - with fraudulent digital signature for given message

MAC vs Digital Signature

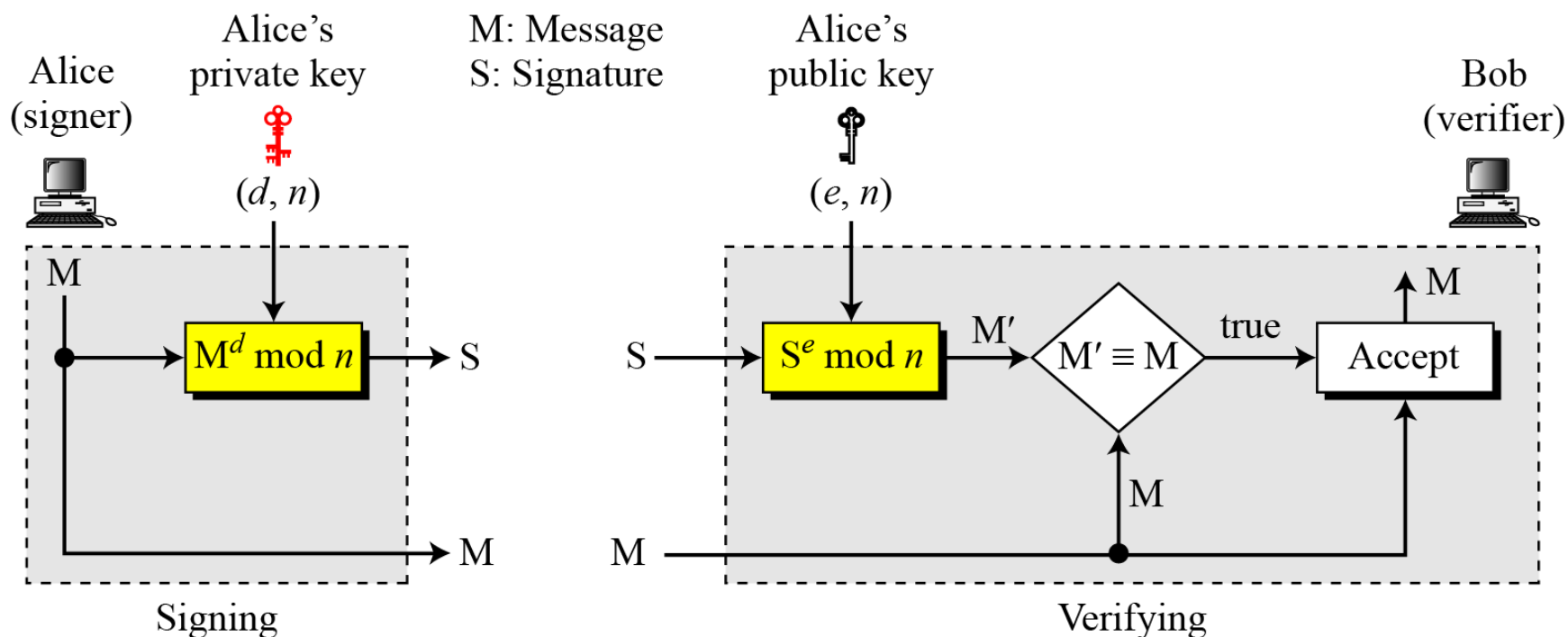
MAC

Digital Signature

- Key distribution has to be done apriori.
- In multi-verifier scenario, a signer/verifier need to hold one secret key for every verifier
- Well-suited for closed organization (university, private company, military). Does not work for open environment (Internet Merchant)
- + Very fast computation. Efficient Communication. Only way to do auth in resource-constrained devices such as mobile, RFID, ATM cards etc
- NO Public Verifiability & Transferability
- NO Non-repudiation (cannot deny only to the person holding the key)

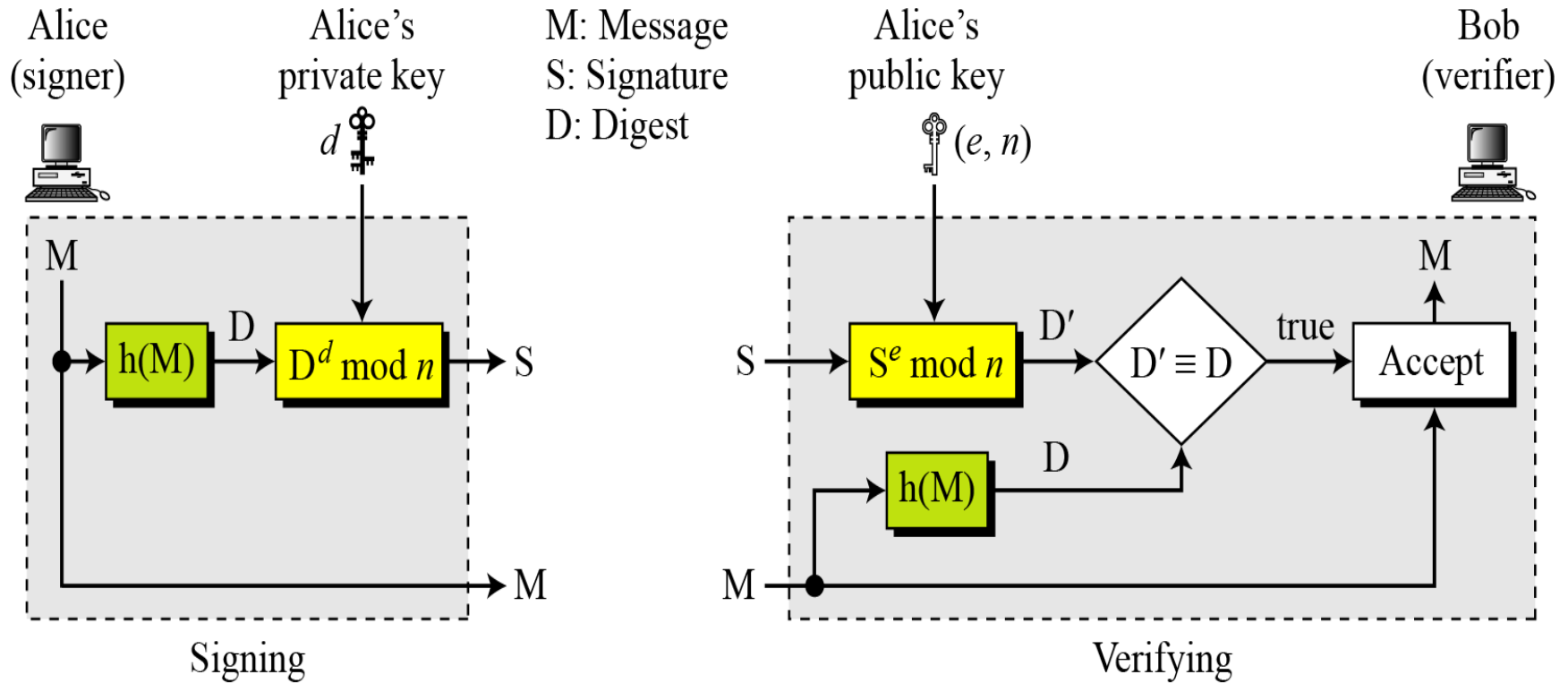
- Not completely correct! Relies on the fact that there is a way to send the public key in an authenticated way to the verifiers
- + One signer can setup a single public-key/secret key and all the verifiers can use the same public key
 - + Better suited for open environment (Internet) where two parties have not met personally but still want to communicate securely (Internet merchant & Customer)
 - Orders of magnitude slower than Private-key. Heavy even for desktop computers while handling many operations at the same time
 - + Public Verifiability & Transferability
 - + Non-repudiation (cannot deny to anyone)

RSA digital signature scheme



In the RSA digital signature scheme, d is private; e and n are public.

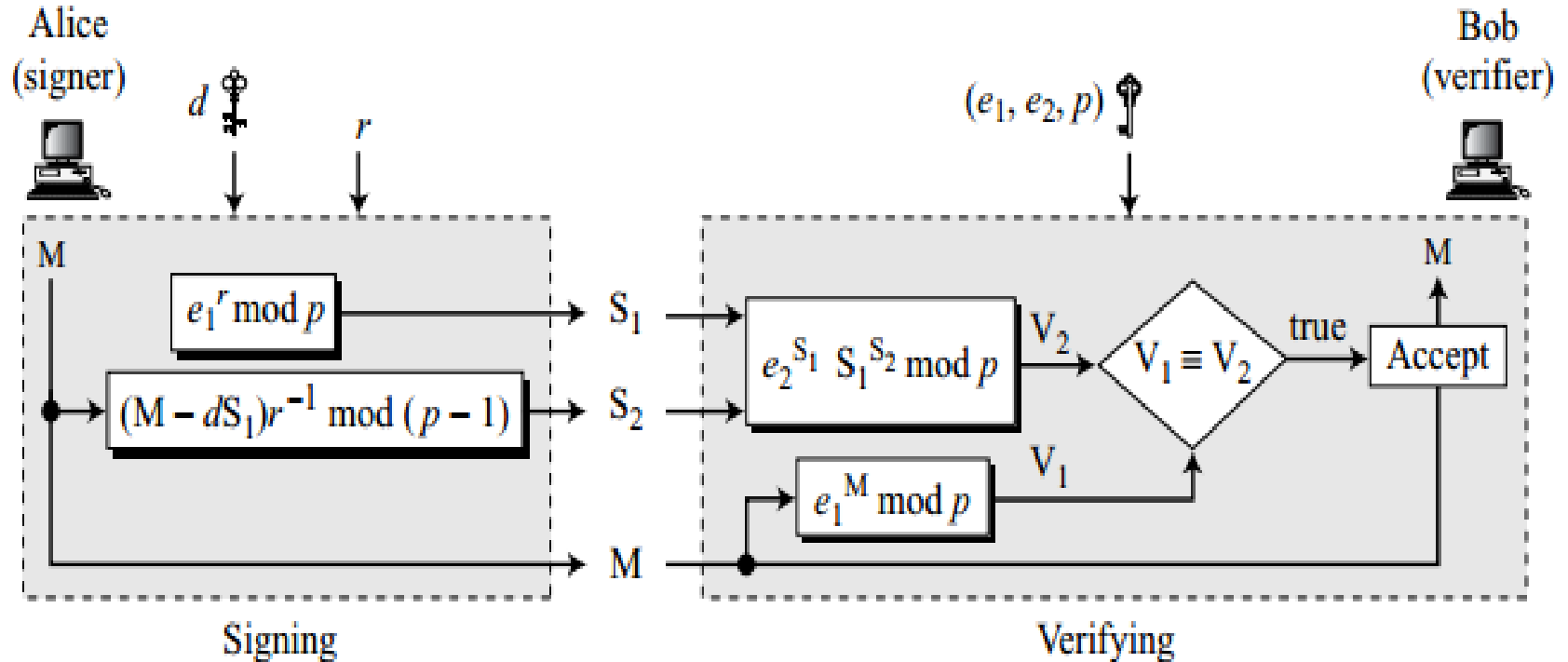
RSA Signature on the Message Digest



- When the digest is signed instead of the message itself, the susceptibility of the RSA digital signature scheme depends on the strength of the hash algorithm.

ElGamal digital signature scheme

M : Message
 S_1, S_2 : Signatures
 V_1, V_2 : Verifications
 r : Random secret
 d : Alice's private key
 (e_1, e_2, p) : Alice's public key



Example

- Suppose, Alice chooses $p = 3119$, $e_1 = 2$, $d = 127$ and calculates $e_2 = 2^{127} \bmod 3119 = 1702$. She also chooses r to be 307. She announces e_1 , e_2 , and p publicly; she keeps d secret. The following shows how Alice can sign a message.

$$M = 320$$

$$S_1 = e_1^r = 2^{307} = 2083 \bmod 3119$$

$$S_2 = (M - d \times S_1) \times r^{-1} = (320 - 127 \times 2083) \times 307^{-1} = 2105 \bmod 3118$$

Alice sends M , S_1 , and S_2 to Bob. Bob uses the public key to calculate V_1 and V_2 .

$$V_1 = e_1^M = 2^{320} = 3006 \bmod 3119$$

$$V_2 = d^{S_1} \times S_1^{S_2} = 1702^{2083} \times 2083^{2105} = 3006 \bmod 3119$$

- Another misuse of the ElGamal signature system is to use the same r to sign two messages. In such a case x can be computed and system can be broken.

Digital Signature Standard (DSS)

- DSA is a modification of ElGamal digital signature scheme. It was proposed in August 1991 and adopted in December 1994.

Digital Signature Standard (DSS)

- uses the SHA hash algorithm
- DSS is the standard, DSA is the algorithm
- Key limit 512 – 1024 bits, only for signature, no encryption
- based on discrete logarithm problem
- Message hash is not restored for verification (difference from RSA)

Digital Signature Standard (DSS)

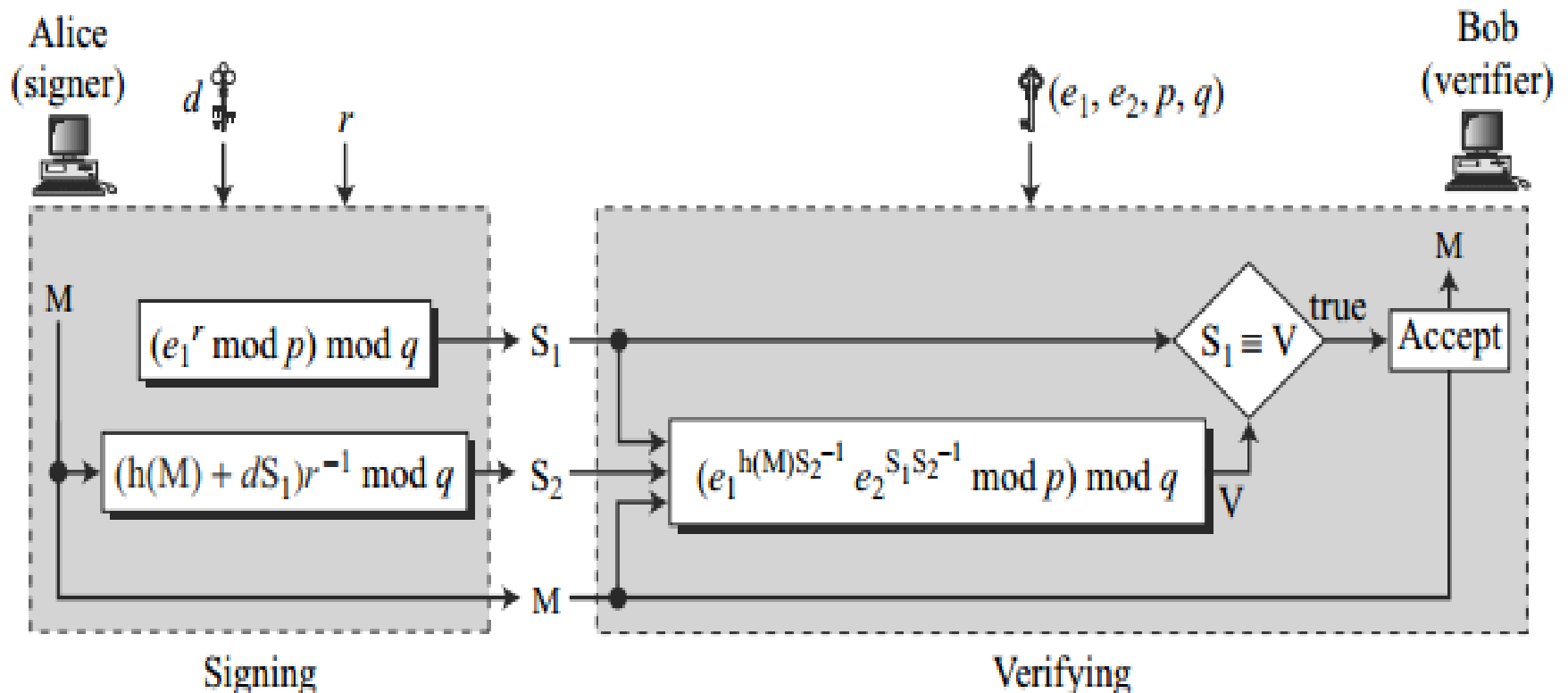
Key Generation

Before signing a message to any entity, Alice needs to generate keys and announce the public ones to the public.

1. Alice chooses a prime p , between 512 and 1024 bits in length. The number of bits in p must be a multiple of 64.
2. Alice chooses a 160-bit prime q in such a way that q divides $(p - 1)$.
3. Alice uses two multiplication groups $\langle \mathbf{Z}_p^*, \times \rangle$ and $\langle \mathbf{Z}_q^*, \times \rangle$; the second is a subgroup of the first.
4. Alice creates e_1 to be the q th root of 1 modulo p ($e_1^p = 1 \bmod p$). To do so, Alice chooses a primitive element in $\mathbf{Z}_p$, e_0 , and calculates $e_1 = e_0^{(p-1)/q} \bmod p$.
5. Alice chooses d as the private key and calculates $e_2 = e_1^d \bmod p$.
6. Alice's public key is (e_1, e_2, p, q) ; her private key is (d) .

DSS Scheme

M: Message **r:** Random secret **h(M):** Message digest
S₁, S₂: Signatures **d:** Alices private key
V: Verification **(e₁, e₂, p, q):** Alice's public key



Breaking of Digital Signatures

- **Total break:**
 - An attacker knows the signing key
- **Universal forgery:**
 - has a function that is equivalent to the signature generation transformation.
- **Selective forgery:**
 - An attacker can generate signatures (without the participation of the legitimate signer) on a set of messages chosen by the attacker.

- Existential forgery:
 - The attacker can generate signatures on certain messages over which the attacker has no control.